

Towards Continuous Security Assessment: Integrating Model-Based Risk Assessment and Large Language Models

Mario Werthwein
Institute for aircraft systems
University of Stuttgart
Stuttgart, Germany
0000-0002-1861-978X

Bjoern Annighoefer
Institute for aircraft systems
University of Stuttgart
Stuttgart, Germany
0000-0002-1268-0862

Zamira Daw
Institute for aircraft systems
University of Stuttgart
Stuttgart, Germany
0000-0003-2623-4959

Abstract—Cyber threats and attacks on aircraft ground infrastructure as well as communication, navigation, and surveillance service providers have increased significantly in recent years. Due to the dynamic nature of cyber threats, a once securely designed architecture will not stay secure throughout its life-cycle. Ensuring the safety and security of large systems of systems requires continuous reassessment of security risks. Currently, while useful building blocks exist, no comprehensive framework supports the continuous and automated risk reassessment in aviation. To address this gap, we propose a conceptual framework that integrates model-based system specification, model-based security assessment, and Large Language Models (LLMs) to automate the continuous reassessment of residual risks in cyber-physical systems. This framework dynamically analyzes and adapts to emerging threats, enabling proactive and up-to-date risk management. This paper outlines the high-level requirements of the proposed framework and presents a state-of-the-art analysis of technology readiness and existing gaps necessary for its implementation. To demonstrate its feasibility and effectiveness, we apply the framework to an Air Traffic Management use case.

Index Terms—Security, Risk Assessment, Large Language Models, Model-based system engineering.

I. INTRODUCTION

For a long time, the playground of cyber-criminals was restricted to the general information technology (IT), especially to the world-wide-web. As time passed, services connected to the web or enabled by it, such as the Internet of Things (IoT), smart devices, and online banking applications, were targets of cyber-attacks [1]. But in the last 20 years, the importance of cyber-security has increased significantly in aviation. There are many reasons for the greater exposure of systems to cyber-criminals. On the one hand, the availability of hacking tools and the knowledge on how to use them. On the other hand, the digitization and innovation in IT besides others. This manifests especially the aviation ground infrastructure as well as aircraft development and manufacturing due to a more technology-open networking and IT approach. The potential vulnerability of air traffic control was investigated and described in a report by the FAA in 2009 [2]. More recently, cyber attacks on air traffic management

(ATM), were conducted. In 2015 hackers targeted the Polish airline LOT, which led to grounding 1400 passengers [3]. In 2021 a targeted attack on the public web domains of several airports in the US was successful, which led to a denial of service of those public services [4]. In 2024 the German air traffic control was the target of a hacker attack, which luckily did not cause disturbance in air traffic, but the data that might have been leaked could not be resolved [5]. In 2020 the certification specification of large aircraft and the acceptable means of compliance (AMC) were amended by AMC 20. Part 20-42 of the amendment states, that assessing cyber-security risks and providing instructions for continued airworthiness is required when approaching certification. The attack surface of an aircraft, concerning intentional unauthorized electronic interactions is small. This is due to the fact, that current aircraft comply to the aircraft network domain concepts from the ARINC 811 Standard [6]. This restrictions to network communication flow inside of an aircraft makes it almost impossible for an attacker to execute an attack targeting the aircraft control domain. In contrast, the supporting structures like airport infrastructure, airline operator infrastructure and the air traffic management expose a greater surface for attacks. Although they do not control the aircraft directly, they contribute to safe and secure operations. Furthermore, the on-board aircraft systems, ground systems are more open to commercial-of-the-shelf (COTS) components and use a more open networking approach.

Assessment of residual cyber risks for a fixed system at a fixed point in time is already an extensive work. If we now consider changes in at least one of the systems, a reassessment is needed. Moreover, discovering vulnerabilities in developed soft- and hardware can lead to changing potential exploits and different executable attacks. As a result, continuous risk assessment is required i.e. regularly checking for vulnerabilities and new cyber attacks applicable to installed soft- and hardware. In conclusion, there is a need for an overarching framework, enabling continuous security risk assessment which is suitable to the aviation domain.

Before specifying the concept framework in this paper, a thorough investigation of already existing frameworks in related fields of research is necessary. In [7] they applied an LLM assisted generation of security properties to support the design of Systems-on-Chip. To achieve this, they proposed a framework that utilizes the strengths of LLMs to extract features and assets from the design specifications as well as from the designed Register-transfer Level specifications. Generated security properties can be translated to formal verification languages, which they verify by using formal property verification methods. In [8] the authors present an approach leveraging large language models (LLMs) to support engineers during preliminary risk assessment. They used fine-tuned models conducting mission critical use-cases, which showed improvements for reducing unwarranted security measures. A similar approach but with a focus on supporting hazard analysis was presented in [9]. The authors invested most of their research effort to evaluate responses of ChatGPT concerning their quality and usability. Besides the stated research current research effort goes into the direction of risk assessment of AI. To the authors knowledge no framework exists that enables ongoing security risk assessment on arbitrary large system of systems.

Consequently, we use this study to propose a conceptual framework that integrates model-based tools and LLMs to enable continuous security assessment for a given system. This framework is derived from an extensive literature review and a systematic analysis of existing gaps. As a result, it is structured around three key modules: a model-based multi-layer architecture description, a multi-agent LLM-driven security assessment and a model-based security risk assessment.

The paper is organized as follows: In II we present the conceptual approach of the framework, logically divided into the three components. We elaborate on the interfaces between the frameworks components and the desired high level requirements. Afterwards we present the three components in detail. Every section for a component is divided in a State-of-the-Art survey, gap identification and the derivation of future research questions. In IV we outline a use case for the framework in the context of Air Traffic Management. We apply our framework to that use-case and present the results. Concluding in V we discuss the evaluation of the conceptual framework with respect to the use case and provide an outlook on the next steps by summarizing the identified research questions.

II. CONCEPTUAL FRAMEWORK

The primary objective of the framework is to automate the continuous security assessment of a given system in compliance to state-of-the-art aircraft regulations. To achieve this, the system must meet the following high-level requirements: Building on these requirements, we propose a framework comprising three interconnected modules, as illustrated in Figure 1: a model-based multi-layer architecture description (MB-MLA), a multi-agent LLM-driven security assessment

TABLE I
HIGH-LEVEL REQUIREMENTS FOR THE CONCEPTUAL FRAMEWORK AND CORRESPONDING RATIONALES

ID	Description	Rationale
HL-REQ-1	The framework must provide a complete model-based architecture description.	The subsequent conduction of the security risk assessment is only valid if the input data includes all necessary specification and information
HL-REQ-2	The framework must assess residual security risks for a given architecture description.	CS 25§1319 demands that systems and functions contributing to the airworthiness of aircraft must be assessed evaluating residual risk of Intentional Unauthorized Electronic Interactions (IUEI)
HL-REQ-3	The framework must check a defined architecture description against defined requirements	Besides the assessment of residual risks, aviation regulations provide requirements that must be fulfilled by systems. Moreover performance and safety requirements need to be ensured under IUEI
HL-REQ-4	The framework must provide a method to dynamically update the assessment with security related information (vulnerabilities, exploits attacks...).	Our frameworks purpose is to ensure continued airworthiness of aircraft and supportive ground systems. Hence, a reassessment must be possible depending on latest cyber-threat information
HL-REQ-5	The frameworks actions must be traceable.	The assessment provided by the framework considers multiple-layers of the specified architecture. Provision of traceability links between the artifacts of the assessment and the requirements and items taken from the model-data is mandatory for aviation regulation certification aspects
HL-REQ-6	The framework must provide security artifacts in machine processable as well as human readable format.	As stated above, the artifacts generated by the risk assessment must be in compliance to aviation regulations. Which means the outcome needs to be in a format humans can evaluate. Since our framework must process the same information automatically it must be provided in machine-readable format in addition.

(secLLM), and a model-based security risk assessment (MB-SRA). In the following subsections the contribution of the modules to the overarching framework and requirements is given. Furthermore, their purpose and working principles as well as interfaces and data flows are defined.

MB-MLA

The MB-MLA must contribute to the requirements HL-REQ-1, HL-REQ-2 and HL-REQ-3. As a result, it must include information about requirements, systems, functions, hardware, software, as well as safety and security measures. Fulfillment of HL-REQ-1 requires information about the architecture under consideration, whereas HL-REQ-3 requires them to be communicated to the MB-SRA in a structured way.

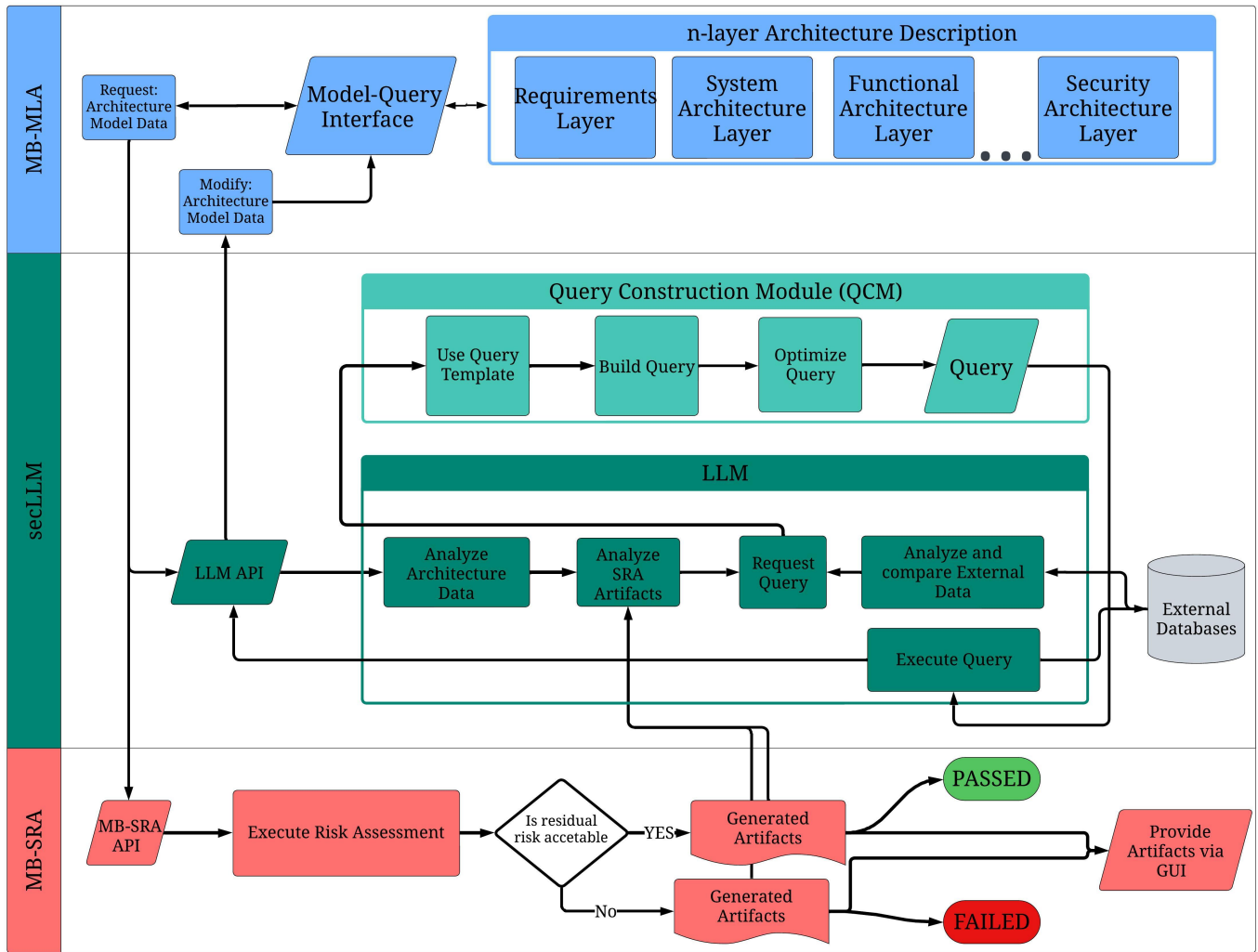


Fig. 1. Overview of the conceptual framework incorporating the modules MB-MLA, secLLM (QCM, LLM), and MB-SRA that shows processes, interfaces and information flows

Besides that, the definition of such an architecture must be done by an engineer. A multi-layered representation of the system fits both needs. With this approach the complexity of the architecture is broken down, relevant information is sorted and interaction between the layers is clearly defined. The information captured within these layers serves as a foundational input for the other modules. The mandatory layers include:

- 1) A requirements layer, which provides constraints and provable properties which must be fulfilled by the complete architecture.
- 2) A system architecture layer, which includes physical components and their interconnections.
- 3) A functional layer, that provides information about the intended function of the system. This layer includes signal and dataflows, functional descriptions and mechanisms on how the data is connected, aggregated and processed.
- 4) The security architecture consists of the description of

security perimeters, security measures and their allocation to system components.

The security perimeter defines an area where the responsibility of dealing with cyber risks is inside of that area [10]. Assumptions about surroundings, or cyber risks that are dealt with externally, which is called the security environment [10] are documented as part of the requirements layer.

As depicted in 1 the MB-MLA provides more than just the multi-layer architecture description. It offers a model-query interface, used by the request and modify functions. Consequently, the multi-layer architectures in- and outputs are queries pre- or post-processed by those functions. They provide the model-data to the other modules in a useful format. Since the model-data is the fundament of the analysis, both functions must ensure consistency. The request function must compile a data request by one of the modules accordingly. The MB-SRA requests the complete multi-layer architecture, whereas the secLLM can request parts or only specific lay-

ers of the architecture. Therefore, the request function must guarantee a complete transfer of model-data with respect to the request and exchange format of the requesting module. The modify function must ensure, that only authorized entities modify the model in a specified and safe manner. Besides that, it is desirable to use a domain-specific model (DSM). The restrictions of a DSM enforce rigidity and completeness which helps in fulfilling HL-REQ-1 and HL-REQ-3. Considering the desired automation by providing the model to the modules secLLM and MB-SRA a DSM is more likely to be processed correctly than other modeling approaches.

secLLM

The secLLM component plays a crucial role in identifying emerging threats within systems that follow a defined architecture (as specified in MB-MLA). It leverages LLMs, security-specific prompt engineering and rule-based AI reasoning to ensure comprehensive threat detection and risk mitigation. By design, secLLM fulfills HL-REQ-4 by dynamically updating security assessments with relevant security information, such as vulnerabilities, exploits, and attacks. Additionally, the QCM module supports HL-REQ-1, HL-REQ-4, and HL-REQ-5, acting as a bridge between MB-MLA and other framework components.

In LLMs, an agent is an autonomous unit that executes tasks using predefined logic, dynamic queries, and interactions with data sources. It analyzes, retrieves, interprets, and generates insights, leveraging an LLM-backed reasoning engine, prompt engineering, and structured data access. The secLLM module consists of three key agents that interact with MB-MLA and MB-SRA to enhance security assessment: 1) The Architecture Analysis Agent examines the architecture model and security assessment results from MB-SRA to identify critical components that require closer monitoring. By pinpointing the most vulnerable or high-risk elements within the system, this agent ensures that emerging threats are proactively addressed before they can be exploited. 2) The Threat Intelligence Agent continuously monitors external sources such as vulnerability databases, exploit repositories, and security incident logs to identify new threats. When relevant security risks are detected, it updates MB-MLA, prompting MB-SRA to reassess the architecture model in light of the latest intelligence. This dynamic process keeps the security assessment aligned with evolving threats. 3) The Security Mitigation Agent focuses on identifying effective security measures, best practices, and compliance requirements from both internal and external sources. Based on this analysis, it proposes mitigation strategies to reduce unacceptable residual risks, ensuring that the system remains secure and resilient against potential attacks. The QCM (Query Construction Module) serves two primary functions: requesting model data for analysis and modifying model data based on security findings. It facilitates structured data retrieval to support security assessments while also enabling updates to the model based on newly identified threats or vulnerabilities. This ensures that the security framework remains dynamic and responsive to evolving risks. QCM

employs rule-based query construction to generate predefined queries for MB-SRA, ensuring a structured approach to security assessment. Queries used for writing model data back are dynamically generated based on LLM findings. Similarly, queries for retrieving external threat intelligence are constructed to allow direct comparison between external databases and internal architectural artifacts from MB-SRA. The LLM in secLLM is accessed primarily through an LLM API, ensuring structured interactions with the framework. The LLM part of secLLM is mainly used via the LLM API. The architecture model data is wrapped with a crafted query to instruct the LLM to follow the process chain as shown in figure 1. The LLM is also able to request specific queries for accessing databases containing parts of the analyzed data. Important is that findings of the LLM can be written back into the MB-MLA, but there is no way to directly influence the processes of the MB-SRA. The focus of this study and the framework is to utilize existing LLMs, by understanding and mitigating their flaws and not developing a new LLM.

MB-SRA

The MB-SRA must contribute to the requirements HL-REQ-2, HL-REQ-4, HL-REQ-5, HL-REQ-6. To comply to the given requirements and also to latest aviation regulations, the MB-SRA aims to derive threat scenarios and potential attack paths through the architecture based on the MB-MLA. Feasible is a solution, where the MB-SRA evaluates the residual risk of a static architecture under specific hostile condition based on defined metrics. These metrics are built on security and safety information (e.g., Fault Detection and Isolation, Redundancy patterns and monitoring). The MB-SRA incorporates the methods to decide on the outcome of the risk assessment, which includes the checking of the results against the requirements. As seen in figure1 the MB-SRA only accepts input via the MB-SRA API. The complete architecture description is provided, which is then translated into the format needed by the risk assessment. HL-REQ-5 requires this process to be traceable. Results of the assessment are presented as artifacts. They need to be traceable to comply not only with HL-REQ-5 but also with HL-REQ-2 and implicitly HL-REQ-1. Reason for that is the requirement of a complete architecture which must be assessed. That demands a complete hence traceable assessment. Afterwards, the generated artifacts are then provided to the LLM for analysis and to a user via a graphical user interface (GUI). After the decision, the framework has completed one iteration, which is shown by the "PASSED" or "FAILED" indication. A new iteration for the framework is triggered if the MB-MLA changes, either by user input or modification via the LLM. The static risk assessment is solely dependent on the input provided by the MB-MLA. There is no dataflow or process from secLLM to MB-SRA.

III. GAP-ANALYSIS OF THE CONCEPTUAL FRAMEWORKS MODULES

Each subsection will target one of the components. For every module a survey on the current state of the art, followed by an identification of gaps that the proposed module must fill, is conducted. Finally, we derive open research questions for each module from the findings.

A. Model-based Multi-Layer-Architecture

NASA presented in [11] a reference model for the Space Generic Open Avionics Architecture (SGOAA). They focused on a description of every level of detail of system architectures, not only on hardware but also on software and low-level software side. A more recent approach to standardization which seems to be a successor of the SGOAA is the Integrated Modular Avionics (IMA) [12]. By standardization of the interface of applications to the operating system and requirements for hardware and software the RTCA DO 297 provides something like a model for avionics architectures. But, both of these approaches are more like reference models, than usable DSM. The usage of DSM promises more rigidity, simplicity and if implemented in the right way, a DSM can be analyzed by model-checking software. There are DSMs that are capable of describing multi-layers of an architecture. Matlab's® System Composer is a tool-suite, which enables engineers to model systems and software architectures. Moreover, requirements as well as behavioral models can be specified. Although system composers offers some safety modeling related functionality, it does not support designated modeling of security measures. Domain Specific Modeling Languages (DSML) that cover parts of the stated layers and are tailored to aviation exist, like the Open Avionics Architecture Model (OAAM) [13] which can be used to consistently represent multiple layers of an avionics system-of-systems architecture. Yet there is a lack of representation of requirements as well as security related properties of components and lastly there is no security architecture layer in OAAM. Although, requirements can be considered partially via the restrictions and allocations layers. Nevertheless, there is no built-in layer which supports formal specification of requirements. In [14] the authors present a partially implemented concept of an integrated system architecting approach for avionics systems. The approach lacks the inherent safety aspects compared to OAAM and is also not designed to support security risk assessment. But it incorporates the idea of using already available model data in a formalized way. In the end that knowledge was taken from Matlab's® System Composer. In [15] the authors expressed a meta-model for safety and security that should support existing MBSE approaches. Integration of such could leverage existing MBSE approaches in avionics. Nevertheless, we identified two areas which seem to be underrepresented in modeling of avionics, the security architecture and the formal requirements layer. In the following we elaborate further on that.

In [16], [17] a framework and the underlying model

description of security architectures and security assessments was developed and applied in the CySeMoL tool. Also modeling approaches for security architectures, like the "Security Meta-model for Software Architecture" besides many models for general business and company level architectures exist. To the authors knowledge there is no security meta model or meta model extension for describing security relevant attributes or propagation of loss of security attributes in avionics systems. Back in 2003 GROOVE (GRaph-based Object-Oriented VERification) was presented [18]. They presented a tool-set, which does software model checking on object-oriented systems. Their tool works on graph transformations. Which means a systems state represented as a graph can be checked formally with that tool.

The formal description of requirements is no new topic in the field of system design, especially considering reliability. With the Timed Abstract State Machine (TASM) language or Temporal Logic CTL, besides others, there are methods to formalize requirements. In [19] a formal software architecture model (SAM) is developed. It is a framework that utilizes Petri nets and temporal logic to describe and specify software architectures formally. It supports different analysis methods, like model checking or interactive proving besides others. Model-checking and proving is realized by the Symbolic Model Verifier [20], and theorem proving with the Stanford Temporal Prover [21]. A model checking framework, especially for avionics systems was developed in [22]. They based their work on existing input defined by model-based development in Simulink and StateFlow as well as the transformation to SCADE and Safe State Machines and from that to the formal specification language Lustre. Their contribution was the transformation of that information to eight different formal analysis tools and a C or Ada source code generator. In [23] an automatic transformation of SCADE models is shown. They make use of the already formalized SCADE model, but also of formally specified requirements. Their contribution is generating provable specifications out of the SCADE model and the requirements. With FASTEN [24] an approach to automate and simplify specification and design of safety-critical systems especially in automotive was presented. They implemented several domain specific languages for formal specification of requirements and coupled this with model-based system descriptions e.g. in SysML.

The state-of-the-art shows, that the needed modeling approaches exist, but are not unified or not tailored to aviation or aircraft systems. A domain-specific modeling language (DSML) that incorporates all necessary layers needed for continuous risk assessment specifically for avionics does not exist. There are tools and methods to formally define requirements and prove them. The challenge lies in the correct formal description of such requirements. Hence, the question is, how can the definition of the requirements be embedded into the MB-MLA, such that

consistent and easy description for aircraft and engineers in the aviation sector is possible. Moreover, research has shown that model-parameter can be used to generate formalized requirements e.g. usage of temporal logic for signal flows. The challenge is to support the engineer in completely and correctly describing requirements for the system. Yet, cyber risks are not probabilistic. Therefore, a formal description of cybersecurity requirements can be difficult. As a result another research question will be on how to describe quantifiable metrics for security which can be used to specify valid requirements. In the end this implies a specification of the security architecture by respecting the same metrics so that a prove against the formalized requirements is reasonable. In conclusion, a necessary addition to the MB-MLA is a requirements layer that specifically supports model-based development. This layer could be semi-auto-generated. Secondly, a security architecture layer including valid boundary conditions and assumptions, as well as security measures assigned to system components is inevitable.

B. *secLLM*

The state of the art in LLM-driven security research demonstrates promising but inconsistent results in both hardware and software security. In hardware security, Saha et al. (2024) [25] explored GPT-3.5-turbo and GPT-4 for vulnerability detection in 10,000 security-aware finite state machine (FSM) designs. The study found that LLMs successfully inserted vulnerabilities with a 97.37% success rate and detected vulnerabilities with 99.07% accuracy after iterative refinement. Similarly, Ayalasomayajula et al. (2024) [7] improved hardware security verification by combining static analysis with LLMs to generate high-quality security properties for System-on-Chip (SoC) designs, addressing limitations of prior approaches that directly analyzed hardware designs with lower efficiency.

In software security, Zhang et al. (2023) [26] evaluated GPT-4's ability to generate security tests for 55 software applications, concluding that well-structured prompts significantly improve performance, though ChatGPT-4 struggles with complex inter-procedural analysis and requires initial test examples for effective exploit generation. In contrast to using an existing LLM, Bokkena et al. (2024) trained an LLM to recognize linguistic and non-linguistic security threat patterns, showing that it outperformed traditional rule-based models, achieving over 95% accuracy, reducing false alarms, and even detecting previously unknown exploits. Li et al. (2024) [27] enhanced security vulnerability detection by combining LLM-based reasoning with static analysis, significantly outperforming traditional tools like CodeQL. The approach reduces reliance on human-labeled data and detects more vulnerabilities with fewer false positives. However, Ullah et al. (2024) [28] assessed LLM reliability across 228 code scenarios in C and Python. The findings revealed that state-of-the-art LLMs, including GPT-4 and PaLM2, suffer from high false positive rates, inconsistent reasoning, and non-deterministic behavior, making them

unreliable for real-world security tasks.

From these studies, we can conclude that LLMs have strong potential for improving security automation, particularly in scalability and adaptability to dynamic threats. However, their reliability and consistency remain open challenges. Research shows that integrating LLMs with traditional analysis techniques (e.g., static analysis and rule-based models) enhances security assessments, particularly in complex security evaluations. A crucial question remains: Should LLMs be used in security-critical applications despite their inconsistencies? While they are not yet fully reliable, LLM-driven security assessments provide greater insight than traditional approaches alone.

C. *Model-Based Security Risk Assessment*

In [29] a model-based framework for security risk assessment is presented. They use an asset approach, which is supported by loss and attack events. Moreover, the modeling of threats and attackers is supported. The risk gets calculated via attack graphs using the Factor Analysis of Information Risk (FAIR) [30] method. Their approach is focused on modeling specific use cases in detail with few automation's shown. An integrated approach combining safety and security in a model-based way is presented in [31]. They define a high-level meta-model, which is used to generate cyber-attack scenarios. To model the underlying system under consideration, they focus on industrial control systems, on a three layer of detail approach. In [32] a risk assessment approach was presented, based on network models and state transfers by utilizing Generalized Stochastic Petri Net (GSPN). They conduct the assessment using the PIPE tool based on a specific denial-of-service attack, which is represented by an attack tree. Result of their assessment is a list of all attack paths and a occurrence probability of them. That probability is based on model transition weights, namely attack cost, technical difficulty and probability to be discovered. In [33]–[36] different approaches to utilize model-based system engineering for different technical use cases were presented. Yet they do not incorporate the aviation regulations and are not fully automated. In [37] the Model-Based Avionics Cybersecurity Framework for Identification of Risk and Evaluation (MACSFIRE) was presented. They developed a framework that conducts automated risk-assessment based on aviation regulations, using the asset-based approach. Moreover, they implemented a first version of it as a python application.

After a suitable method for building threat scenarios is defined, the evaluation of residual risk is due. Judging risk purely qualitatively is not sufficient for a continuous and automated approach as we suggest it here. The already mentioned FAIR model, aims to quantify risk by utilizing relational probabilities and statistics as quantification methods. They broke down the likelihood of occurrence of risk into abstractly modeled factors and applied those quantification methods on them. Similar approaches of risk quantification are

used in [38]–[40], varying from utilizing Bayesian methods, including parameters to evaluate effectiveness of protections or usage of analytics in a financial risk model. For medical devices in trusted networks, the authors of [41] used the NIST SP800-30 Risk Assessment Process steps and modified the conduction of assessment to quantify risk. They introduced a threat source capability, judged threat event frequency and single loss event magnitude. Which has two of the three factors in common with the FAIR model. Vulnerabilities were used as predisposing conditions utilizing CVSS and CVE. In [42] the authors focus on quantifying MITRE attack campaigns. They make use of attack trees and a method they developed in [43] which attributes the formal representation of attack trees with metrics like cost, skill and probability. Result is a calculated security index for a given MITRE attack campaign represented by an attack tree. What all metrics have in common is that they abstract risk into factors and use them for quantification to a specified extent. They all agree on risk being the product of frequency of an adverse event happening and the impact of that event. That commonality can also be seen in the RTCA DO-326 and 356 [10], [44].

The state-of-the-art study shows, that quantification of risk of a cyber-attack is still tied to manual work and the metrics are hardly understandable for algorithms. The question is: What is the missing part that glues together the stated quantification, to be usable by the continuous risk assessment algorithm. As it was already discussed in the MB-MLA state-of-the-art survey, the problem originates not only from quantification of risk but also from the metrics describing cybersecurity in general. Reason for that is their connection through the impact of a successful attack and the attack mechanism. A compromise between a simple and abstract model and a complex but specific model of cybersecurity properties and corresponding metrics must be found. To fully leverage the automated MB-SRA the metrics must be usable to include security measures. For the MB-SRA it must be understandable if a given security measure is preventing, hindering or detecting attacks. The metrics must include a description of cybersecurity properties that can be coupled with attacks, security measures and goals of the attack. According to the state-of the art research and the demands from the aviation regulations a usable quantification method of risk for the proposed framework must include the:

- 1) $Likelihood_{ap}$ describing how likely a chain of actions is successful that lead to the event with
- 2) the $Impact_{target}$ which e.g. correlates to the failure conditions of aircraft and that is reduced by the
- 3) SecurityMeasureScore (SMS), that only includes measures reducing the impact (SMS_{impact}) of manifested risk.

The $Likelihood_{ap}$ is factorized by the:

- 1) Attacker's profile which translates to the AttackerProfileScore (APS) and the
- 2) accessibility and usability of the attack vector which

translates to the AttackerProfileScore (AVS) and lastly the

- 3) $LateralMovementScore_i$ segment, which describes the complexity of every step throughout the attack path. It equals 1 if no further attacker actions are necessary and no security measures are in place. Otherwise it consists of:
 - a) AttackerProfileScore (ACS) which can be described by approaches like the CyberKillChain and is reduced by the
 - b) SMS_{lh} which includes all measures that target reduction of attack likelihood. Lastly, the
 - c) SMS_{stop} which is either 1 or 0. If a security measures does prevent an attack that contributes to the ACS, the SMS_{stop} , while the security measure is intact.

The challenge is to detail and specify the contributing factors to those scores and project them on unambiguous and machine-understandable propagation of the loss of cybersecurity properties CIA. This could also mean, that an extended or modified version of the CIA triad does fit the purpose better. It should resemble in an equation like equation 1:

$$\begin{aligned}
 Risk_{ap} &= Likelihood_{ap} * \frac{Impact_{target}}{SMS_{impact}} \\
 Likelihood_{ap} &= APS * AVS * \prod_{i=1}^n LateralMovementScore_i \\
 LateralMovementScore_i &= SMS_{stop} * \frac{ACS}{SMS_{lh}} \quad (1)
 \end{aligned}$$

If such a quantification exists and it is provable against the requirements, the MB-SRA must be complete, traceable and correct. As discussed, approaches for that exist, but to the authors knowledge there is no certified engine that transforms existing model-based system specifications into the asset-based approach. Moreover there is qualified tool, that incorporates an algorithm which calculates risk of threat scenarios in compliance to aviation regulations automatically. Furthermore, none of the identified existing studies showed generated artifacts for human interaction in full compliance to aviation regulations. Specific to the conceptual framework presented in this study is also the connection to the secLLM. The questions is how the results of the MB-SRA can be communicated effectively and understandable to a LLM.

IV. USE CASE: AIR TRAFFIC MANAGEMENT

This section presents a use case demonstrating the practical application of the proposed framework for continuous security assessment in Air Traffic Management (ATM). ATM involves multiple organizations, diverse infrastructure, and numerous interconnected systems. The complexity of these components and their varied ownership structures highlight the need for an automated tool capable of analyzing evolving security scenarios. To illustrate this, we define a use case that simplifies ATM operations while preserving key security considerations. As depicted in Figure 2, the use case focuses on voice com-

Layer	ID	Name	Type	Allocation
System Architecture	SA-1	Aircraft	System-of-systems	N/A
System Architecture	SA-2	Satellite	System-of-systems	N/A
System Architecture	SA-3	Radar ground station (gs)	System-of-systems	N/A
System Architecture	SA-4	SATCOM ground station (gs)	System-of-systems	N/A
System Architecture	SA-5	Airband ground station (gs)	System-of-systems	N/A
System Architecture	SA-6	Firewall Server	Hardware +Software	N/A
System Architecture	SA-7	Router	Hardware +Software	N/A
System Architecture	SA-8	Storage Server	Hardware +Software	N/A
System Architecture	SA-9	Backup Server	Hardware +Software	N/A
System Architecture	SA-10	Internal Devices	Hardware +Software	N/A
System Architecture	SA-11	ATC Operator	Human	N/A
Functional Architecture	FA-1	uni-directional "communication" with aircraft and radar gs	Function	SA-1,SA-3
Functional Architecture	FA-2	Bi-directional communication with satellite and SATCOM gs	Function	SA-2,SA-4
Functional Architecture	FA-3	Bi-directional communication with aircraft and satellite	Function	SA-1,SA-2
Functional Architecture	FA-4	Bi-directional communication with aircraft and airband gs	Function	SA-1,SA-5
Functional Architecture	FA-5	Receive and provide communication with aircraft	Function	SA-11
Security Architecture	SM-1	Firewall	Security Measure	SA-6
Security Architecture	SM-2	Password protection	Security Measure	SA-10
Security Architecture	SM-3	Network segmentation	Security Measure	SA-7
Security Architecture	SM-4	Access Control	Security Measure	[SA-6 ... 11]

Fig. 3. Excerpt of information retrieved from MB-MLA used by MB-SRA, including system, functional and security architecture as well as the allocations between each other

This query requests security insights for a specific firewall type. Below an excerpt of that firewall configuration can be seen, from now on omitted parts are depicted by {.....}:

```

1 <?xml version="1.0" encoding="UTF-8"?>
2 <ServerConfiguration>
3   <Server>
4     <Name>FirewallServer</Name>
5     <Role>Firewall</Role>
6     <Hardware>
7       <CPU>Cores: 8, Speed: 3.5GHz</CPU>
8       <RAM>16GB</RAM>
9       <Storage>SSD 256GB</Storage>
10      <NetworkInterfaces>
11 {.....}
12    </NetworkInterfaces>
13  </Hardware>
14  <Software>
15    <OperatingSystem>Linux - Hardened Kernel
16      6.5</OperatingSystem>
17    <FirewallSoftware>
18      <Component>
19        <Name>iptables</Name>
20        <Version>1.8.8</Version>
21      </Component>
22      <Component>
23        <Name>nftables</Name>
24        <Version>1.0.2</Version>
25      </Component>
26      <Component>
27        <Name>Suricata</Name>
28        <Version>6.0.0</Version>
29      </Component>
30    </FirewallSoftware>
31    <SecurityModules>
32      <Module>
33        <Name>Fail2Ban</Name>
34        <Version>0.11.2</Version>
35      </Module>
36      <Module>
37        <Name>Snort</Name>
38        <Version>3.1.30.0</Version>
39      </Module>

```

```

39      <Module>
40        <Name>SELinux</Name>
41        <Version>3.3</Version>
42      </Module>
43    </SecurityModules>
44  </Software>
45 {.....}
46 </ServerConfiguration>

```

In response, the LLM analyzes external vulnerability databases and identifies relevant Common Vulnerabilities and Exposures (CVEs), assessing their impact on the Confidentiality, Integrity, and Availability Triad. Once vulnerabilities are identified, the MB-MLA module processes the findings and could integrate additional security measures to enhance system resilience. Subsequently, the next iteration of the process begins with a renewed MB-SRA security assessment, ensuring continuous monitoring and adaptation to emerging threats. In this example the LLM found vulnerabilities in the used Suricata version 6.0.0 for the firewall. Exemplary we depict the answers from the LLM concerning one of the vulnerabilities:

```

1 Upon reviewing the available information, the
2 following vulnerabilities have been identified
3 for Suricata versions prior to 6.0.19:
4 1. CVE-2024-32867:
5   Description: Suricata, prior to versions 7.0.5
6   and 6.0.19, has various issues in handling
7   fragmentation anomalies, which can lead to
8   misdetection of rules and policies.
9   CVSS Score: 5.3 (Medium)
10  CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:
11  N/I:L/A:N
12  Impact on CIA Triad:
13    Integrity: The misdetection of rules and
14    policies can lead to unauthorized
15    actions or access, compromising the
16    integrity of the system.
17 {.....}
18 Conclusion: Suricata versions prior to 6.0.19 are

```

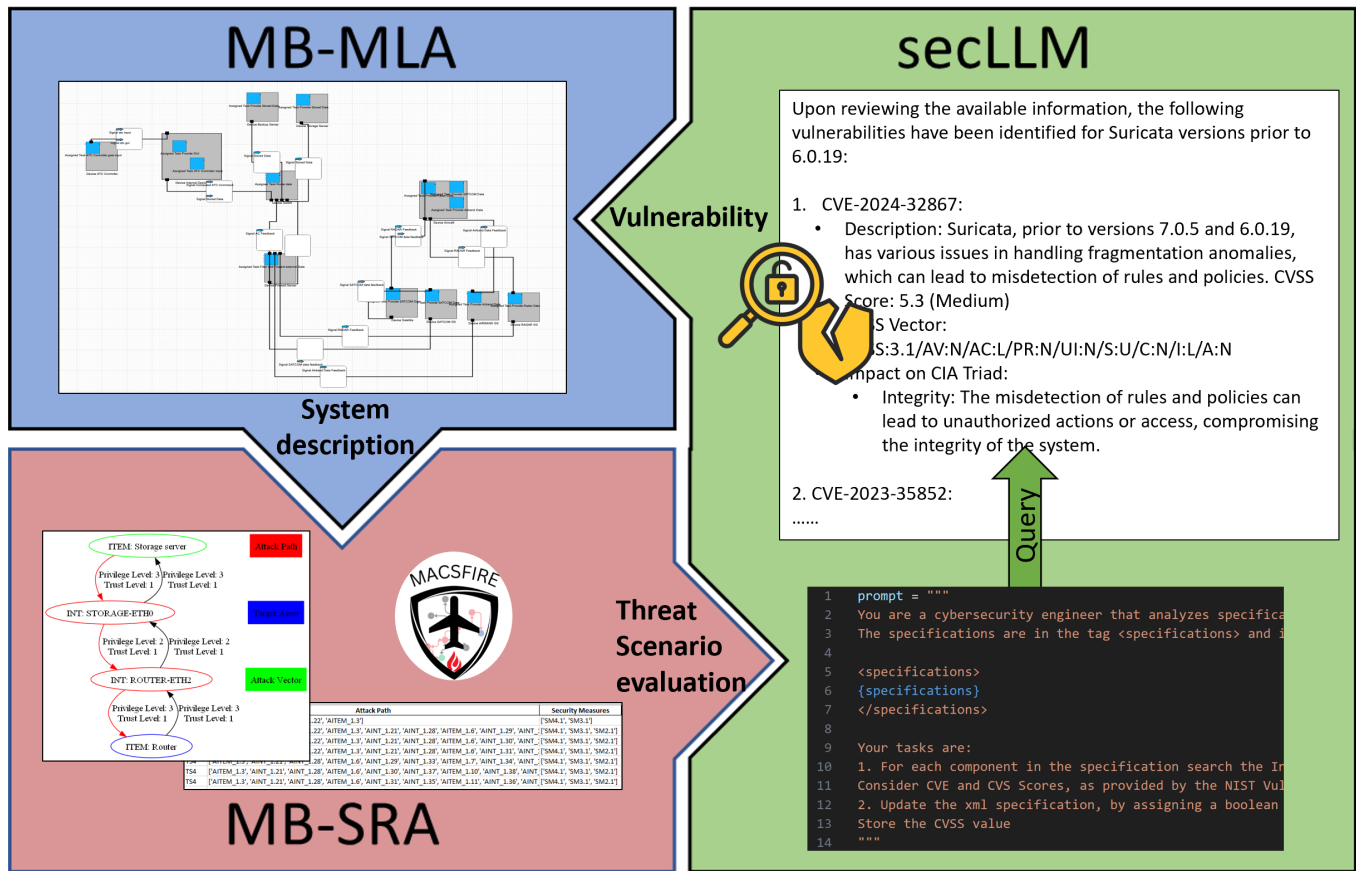


Fig. 4. Flow diagram of the use case incorporating the frameworks modules and their information exchange

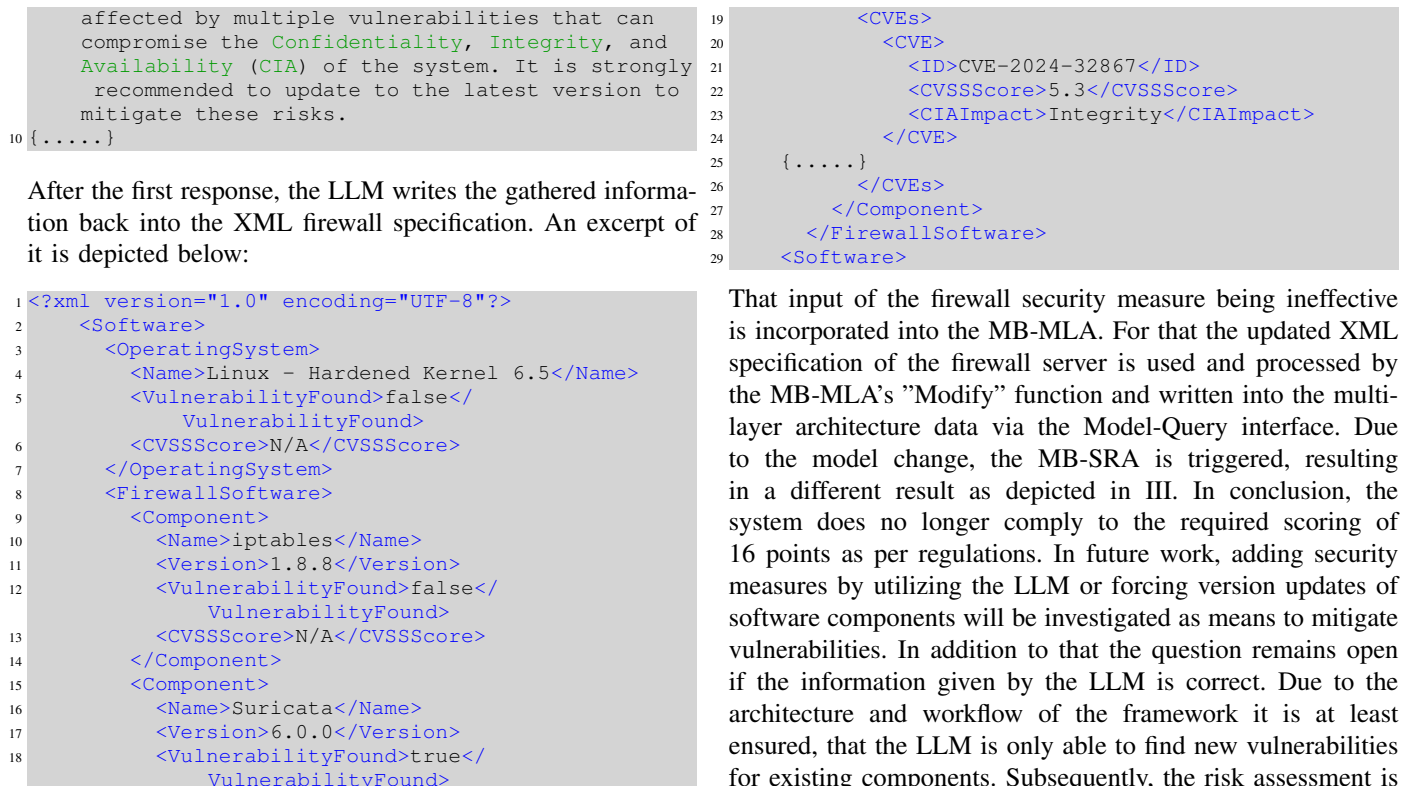


TABLE III

THREAT SCENARIOS RISK SCORING EXCERPT FROM MACSFIRE OUTPUT
AFTER VULNERABLE SM-1 (SCORE 0 INSTEAD OF 6)

Threat Scenario ID	Attack Path	Security Measures	Scoring
TS1	[Storage Server, Router, Firewall Server]	[SM-4,SM-3,SM-1]	12
TS2	[Router, Firewall Server]	[SM-4,SM-3,SM-1]	12

more conservative, or more precise it overestimates risk.

V. CONCLUSION

This paper introduced a conceptual framework for continuous security assessment in aviation, integrating model-based system engineering, security risk assessment, and Large Language Models. The framework aims to automate risk reassessment in cyber-physical systems by dynamically incorporating external threat intelligence while ensuring compliance with aviation cybersecurity regulations. The analysis of the state of the art reveals that while the necessary technologies exist, several gaps must be addressed to fully implement the proposed framework: 1) Current model-based system engineering lacks a dedicated security modeling layer for defining cybersecurity requirements and controls. 2) Risk assessments remain largely static and manual, whereas our framework introduces a continuous, automated approach. 3) While LLMs show promise in security assessments, their reliability in real-world applications requires further validation. 4) Machine-readable cybersecurity metrics aligned with aviation safety regulations are still underdeveloped, requiring additional research to bridge the gap between qualitative and quantitative risk evaluation.

To validate the framework, it is applied to an Air Traffic Management use case, focusing on secure voice communication between an aircraft and an Air Traffic Controller. Although the framework is not yet fully implemented and automated, it successfully conducted risk assessment on a defined multi-layer system architecture. It identified vulnerabilities, for example a security flaw in the firewall software (Suricata 6.0.0). Afterwards, the identified vulnerabilities were written back into the multi-layer architecture. In the end, an updated risk assessment evaluated the changes. This iterative process demonstrated the framework's capability to detect emerging threats and adapt risk assessments in real time. Future work will focus on the full implementation and automation of the framework, as well as a comprehensive evaluation of its reliability and effectiveness in real aviation security applications.

ACKNOWLEDGMENT

This paper is based on research work carried out in the RESISTANT project (contract code: 20D2116A) funded by the German Federal Ministry for Economic Affairs and Climate Action (BMWK) in the LuFo 6-2 program.

REFERENCES

- [1] "Cyber-Security-in-Financial-Sector-Development-Challenges-and-Potential-Solutions-for-Financial-Inclusion.pdf." [Online]. Available: <https://documents1.worldbank.org/curated/en/209721593689624542/pdf/Cyber-Security-in-Financial-Sector-Development-Challenges-and-Potential-Solutions-for-Financial-Inclusion.pdf>
- [2] R. C. Leng, "Faa web applications security and intrusion detection in air ..." May 2009. [Online]. Available: https://www.oig.dot.gov/sites/de-fault/files/ATC_Web_Report.pdf
- [3] R. Marsh, "Hackers successfully ground 1,400 passengers | CNN Politics," Jun. 2015. [Online]. Available: <https://www.cnn.com/2015/06/22/politics/lot-polish-airlines-hackers-ground-planes/index.html>
- [4] A. B. C. News, "Cyberattacks reported at US airports." [Online]. Available: <https://abcnews.go.com/Technology/cyberattacks-reported-u-s-airports/story?id=91287965>
- [5] "Cyber-Attacke auf Deutsche Flugsicherung," Sep. 2024. [Online]. Available: <https://www.br.de/nachrichten/deutschland-welt/cyber-attacke-auf-deutsche-flugsicherung,UN7rsL4>
- [6] Airlines Electronic Engineering Committee (AEEC), "Guidelines for Aeronautical Security," ARINC, Annapolis, MD, USA, Tech. Rep. ARINC 811, 2013, guidelines for securing aircraft systems and data.
- [7] A. Ayalasomayajula, R. Guo, J. Zhou, S. K. Saha, and F. Farahmandi, "LASP: LLM Assisted Security Property Generation for SoC Verification," in *Proceedings of the 2024 ACM/IEEE International Symposium on Machine Learning for CAD*, ser. MLCAD '24. New York, NY, USA: Association for Computing Machinery, Sep. 2024, pp. 1–7. [Online]. Available: <https://dl.acm.org/doi/10.1145/3670474.3685967>
- [8] M. Esposito and F. Palagiano, "Leveraging large language models for preliminary security risk analysis: A mission-critical case study," in *Proceedings of the 28th International Conference on Evaluation and Assessment in Software Engineering*, ser. EASE '24. New York, NY, USA: Association for Computing Machinery, 2024, p. 442–445. [Online]. Available: <https://doi.org/10.1145/3661167.3661226>
- [9] S. Diemert and J. H. Weber, "Can large language models assist in hazard analysis?" in *Computer Safety, Reliability, and Security. SAFECOMP 2023 Workshops: ASSURE, DECSos, SASSUR, SENSEI, SRTtoTS, and WAISE, Toulouse, France, September 19, 2023, Proceedings*. Berlin, Heidelberg: Springer-Verlag, 2023, p. 410–422. [Online]. Available: https://doi.org/10.1007/978-3-031-40953-0_35
- [10] RTCA Special Committee 216 (SC-216), "Airworthiness Security Process Specification," RTCA, Inc., Washington, D.C., USA, Tech. Rep. RTCA DO-326A, 2014, covers airworthiness and cybersecurity considerations.
- [11] R. B. Wray and J. R. Stovall, "Space Generic Open Avionics Architecture (SGOAA) reference model technical guide," Tech. Rep. NAS 1.26:188246, Apr. 1993, nTRS Author Affiliations: Lockheed Engineering and Sciences Co. NTRS Document ID: 19930021843 NTRS Research Center: Legacy CDMS (CDMS). [Online]. Available: <https://ntrs.nasa.gov/citations/19930021843>
- [12] RTCA, Inc., "Rtca do-297: Software considerations in airborne systems and equipment certification," RTCA, Inc., Washington, D.C., RTCA Document DO-297, 2011, available online at: <https://www.rtca.org>.
- [13] B. Annighoefer, "An Open Source Domain-Specific Avionics System Architecture Model for the Design Phase and Self-Organizing Avionics," *SAE International Journal of Advances and Current Practices in Mobility*, vol. 1, no. 2, pp. 429–446, Mar. 2019, publisher: SAE International. [Online]. Available: <https://saemobilus.sae.org/articles/open-source-domain-specific-avionics-system-architecture-model-design-phase-self-organizing-avionics-2019-01-1383>
- [14] N. Kuelper, T. Bielsky, J. Broehan, and F. Thielecke, "Model-based Framework for Data and Knowledge-Driven Systems Architecting Demonstrated on a Hydrogen-Powered Concept Aircraft," *INCOSE International Symposium*, vol. 33, pp. 666–688, Aug. 2023.
- [15] A. Hovemann, J. Tekaar, S. Japs, H. Anacker, and R. Dumitrescu, *ICED21 - METAMODEL FOR SAFETY AND SECURITY INTEGRATED SYSTEM ARCHITECTURE MODELING*, Aug. 2021, vol. 1, journal Abbreviation: Proceedings of the Design Society Pages: 2036 Publication Title: Proceedings of the Design Society.
- [16] T. Sommestad, "A framework and theory for cyber security assessments," Ph.D. dissertation, Placeholder University, Jan. 2012, iSNB: 9789175015118 Pages: 246.

- [17] T. Sommestad, M. Ekstedt, and H. Holm, "The Cyber Security Modeling Language: A Tool for Assessing the Vulnerability of Enterprise System Architectures," *Systems Journal, IEEE*, vol. 7, pp. 363–373, Sep. 2013.
- [18] A. Rensink, *The GROOVE simulator: A tool for state space generation*, Sep. 2003, vol. 3062, pages: 485.
- [19] X. He, H. Yu, T. Shi, J. Ding, and Y. Deng, "Formally analyzing software architectural specifications using SAM," *Journal of Systems and Software*, vol. 71, no. 1, pp. 11–29, Apr. 2004. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0164121202000870>
- [20] K. L. McMillan, "Symbolic Model Checking," in *Verification of Digital and Hybrid Systems*, M. K. Inan and R. P. Kurshan, Eds. Berlin, Heidelberg: Springer, 2000, pp. 117–137. [Online]. Available: https://doi.org/10.1007/978-3-642-59615-5_6
- [21] Z. Manna, A. Anuchitanukul, N. Björner, A. Browne, E. Chang, M. Colon, L. de Alfaro, H. Devarajan, H. Sipma, and T. Uribe, "Step: The stanford temporal prover," Stanford, CA, USA, Tech. Rep., 1994.
- [22] D. Cofer, M. Whalen, and S. Miller, *Software model checking for avionics systems*, Nov. 2008, pages: 1.
- [23] H. Wang, Z. Yang, Y. Zhou, X. Wang, W. Deng, and W. Li, "AGVTS: Automated Generation and Verification of Temporal Specifications for Aeronautics SCADE Models," Sep. 2024, pp. 338–355.
- [24] D. Ratiu, A. Nordmann, P. Munk, C. Carlan, and M. Völter, "FASTEN: An Extensible Platform to Experiment with Rigorous Modeling of Safety-Critical Systems," Apr. 2021.
- [25] D. Saha, K. Yahyaei, S. Kumar Saha, M. Tehranipoor, and F. Farahmandi, "Empowering Hardware Security with LLM: The Development of a Vulnerable Hardware Database," in *2024 IEEE International Symposium on Hardware Oriented Security and Trust (HOST)*, May 2024, pp. 233–243, iSSN: 2765-8406. [Online]. Available: <https://ieeexplore.ieee.org/abstract/document/10545393>
- [26] Y. Zhang, W. Song, Z. Ji, Danfeng, Yao, and N. Meng, "How well does LLM generate security tests?" Oct. 2023, arXiv:2310.00710 [cs]. [Online]. Available: <http://arxiv.org/abs/2310.00710>
- [27] Z. Li, S. Dutta, and M. Naik, "LLM-Assisted Static Analysis for Detecting Security Vulnerabilities," Nov. 2024, arXiv:2405.17238 [cs]. [Online]. Available: <http://arxiv.org/abs/2405.17238>
- [28] S. Ullah, M. Han, S. Pujar, H. Pearce, A. Coskun, and G. Stringhini, "LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities (Yet?): A Comprehensive Evaluation, Framework, and Benchmarks," in *2024 IEEE Symposium on Security and Privacy (SP)*. San Francisco, CA, USA: IEEE, May 2024, pp. 862–880. [Online]. Available: <https://ieeexplore.ieee.org/document/10646663/>
- [29] M. Ekstedt, Z. Afzal, P. Mukherjee, S. Hacks, and R. Lagerström, "Yet another cybersecurity risk assessment framework," *International Journal of Information Security*, Jul. 2023. [Online]. Available: <https://doi.org/10.1007/s10207-023-00713-y>
- [30] J. Freund and J. Jones, *Measuring and Managing Information Risk: A FAIR Approach*. Butterworth-Heinemann, Aug. 2014, google-Books-ID: oAR0AwAAQBAJ.
- [31] T. Oueidat, J.-M. Flaus, and F. Massé, "A new model-based risk analysis approach that generate cyberattacks scenarios and combine them with safety risks," in *ESREL 2019 - 31st European Safety and Reliability Conference*, Angers, France, Sep. 2021. [Online]. Available: <https://hal.science/hal-03355097>
- [32] L. M. Almutairi and S. Shetty, "Generalized stochastic Petri Net model based security risk assessment of software defined networks," in *MILCOM 2017 - 2017 IEEE Military Communications Conference (MILCOM)*, Oct. 2017, pp. 545–550, iSSN: 2155-7586.
- [33] K. Tam and K. Jones, "MaCRA: a model-based framework for maritime cyber-risk assessment," *WMU Journal of Maritime Affairs*, vol. 18, no. 1, pp. 129–163, Mar. 2019. [Online]. Available: <https://doi.org/10.1007/s13437-019-00162-2>
- [34] R. Wirtz and M. Heisel, "Model-Based Risk Analysis and Evaluation Using CORAS and CVSS," in *Evaluation of Novel Approaches to Software Engineering*, ser. Communications in Computer and Information Science, E. Damiani, G. Spanoudakis, and L. A. Maciaszek, Eds. Cham: Springer International Publishing, 2020, pp. 108–134.
- [35] N. Mohammadi, L. Goeke, M. Heisel, and M. Surridge, "Systematic Risk Assessment of Cloud Computing Systems using a Combined Model-based Approach," in *Proceedings of the 22nd International Conference on Enterprise Information Systems*. Prague, Czech Republic: SCITEPRESS - Science and Technology Publications, 2020, pp. 53–66. [Online]. Available: <http://www.scitepress.org/DigitalLibrary/Link.aspx?doi=10.5220/0009342700530066>
- [36] R. R. Althar, D. Samanta, M. Kaur, D. Singh, and H.-N. Lee, "Automated Risk Management Based Software Security Vulnerabilities Management," *IEEE Access*, vol. 10, pp. 90 597–90 608, 2022, conference Name: IEEE Access.
- [37] M. Werthwein and B. Annighoefer, "Model-based avionics cybersecurity framework for identification of risk and evaluation," in *2024 AIAA DATC/IEEE 43rd Digital Avionics Systems Conference (DASC)*, 2024, pp. 1–10.
- [38] F. Purushottam, "Probabilistic Risk Assessment in Cybersecurity: Bayesian Methods for Quantifying and Mitigating Cyber Risks," *Panamerican Mathematical Journal*, vol. 33, pp. 45–59, Jul. 2024.
- [39] V. Yermoshyn, "CONTROL OF CYBER SECURITY PARAMETERS AS A MECHANISM FOR EVALUATING THE EFFECTIVENESS OF PROTECTION AND FORECASTING THE SITUATION," *Cybersecurity: Education, Science, Technique*, vol. 1, pp. 51–58, Sep. 2024.
- [40] G. Areo, "Cybersecurity Metrics That Matter: Leveraging Analytics to Quantify Risk and ROI," Nov. 2024.
- [41] M. Devender and J. McDonald, "A Quantitative Risk Assessment Framework for the Cybersecurity of Networked Medical Devices," *International Conference on Cyber Warfare and Security*, vol. 18, pp. 402–411, Feb. 2023.
- [42] S. Nicoletti, M. Lopuhaä-Zwakenberg, M. Stoelinga, F. Massacci, and C. Budde, *How hard can it be? Quantifying MITRE attack campaigns with attack trees and cATM logic*, Oct. 2024.
- [43] S. Nicoletti, M. Lopuhaä-Zwakenberg, E. Hahn, and M. Stoelinga, "ATM: A Logic for Quantitative Security Properties on Attack Trees," Oct. 2023, pp. 205–225.
- [44] RTCA Special Committee 216 (SC-216), "Airworthiness Security Methods and Considerations," RTCA, Inc., Washington, D.C., USA, Tech. Rep. RTCA DO-356A, 2018, provides guidance on airworthiness security methods and considerations.